Güvenlik Eğitiminin Anatomisi: Temelden Uygulamaya

ÖFY

October 2026

Özet

Siber güvenlik eğitimi tek bir doğrusal yol değil, birbirini önceleyen katmanlardan oluşan bir yapıdır. İncelenen Udemy kursları dağınık başlıklar altında sunulsa da, içerikleri yalnızca sekiz temel ders kümesine indirgenir: ağ temelleri, işletim sistemi ve sistem güvenliği, kriptografi, ağ ve sistem saldırıları, web uygulama güvenliği, savunma ve izleme, dijital adli analiz, ve yönetişim ile uyumluluk. Bu kümeler bir hiyerarşi oluşturur; ağ temelleri ve kriptografi bilinmeden saldırı teknikleri ezbere kalır, savunma tarafı ise saldırı tarafı anlaşılmadan yüzeysel olur. Kursların büyük çoğunluğu aynı çekirdek konuları farklı sıralarla ve farklı derinliklerde tekrar eder; bir müfredat kurarken asıl mesele yeni başlık eklemek değil, bu sekiz kümeyi doğru sırayla ve doğru derinlikte dizmektir. Sertifikalar (Network+, Security+, CySA+, CISSP) bu kümelerin belirli kombinasyonlarını paketler; dolayısıyla sertifika başlığı değil, altındaki konu kümesi dersin asıl içeriğidir.

Giriş

Siber güvenlik, bilişim sistemlerinin yetkisiz erişime, bozmaya ve ifşaya karşı korunması disiplinidir. Alan iki geniş yönelim barındırır: saldırı tarafı, bir sistemin zayıflıklarını saldırganın bakışıyla bulan ofansif güvenlik (*offensive security*); ve savunma tarafı, sistemleri izleyip saldırıları tespit eden ve yanıtlayan defansif güvenlik (*defensive security*). Sektörde bu iki yönelim sırasıyla kırmızı takım (*red team*) ve mavi takım (*blue team*) olarak adlandırılır.

Bir müfredat kurarken karşılaşılan temel sorun, piyasadaki kurs başlıklarının bir öğretim mantığına göre değil pazarlama mantığına göre adlandırılmış olmasıdır. "Sıfırdan etik hacker", "siber güvenlik uzmanı ol", "bug bounty ile para kazan" gibi başlıklar farklı ürünler gibi görünse de, altlarındaki teknik içerik büyük ölçüde örtüşür. Bir öğrenci için "Learn Ethical Hacking From Scratch" ile bir Security+ kursunun ilk üçte biri aynı ağ ve sistem temellerini anlatır.

Bu yüzden ders çıkarırken başlıkları değil konu kümelerini esas almak gerekir. Bir konu kümesi, birlikte öğrenilmesi anlamlı olan ve aynı ön bilgiyi paylaşan tutarlı bir bilgi bloğudur. Aşağıda, incelenen kursların tamamının dağıldığı sekiz çekirdek küme tanımlanır. Her küme için o kümeyi öğreten kurslar, kümenin kapsadığı alt konular ve kümenin müfredattaki yeri açıklanır. Son bölümde bu kümelerden nasıl somut bir ders dizisi kurulacağı ele alınır.

Kümelerin bir önkoşul ilişkisi vardır. Ağ temelleri ve işletim sistemi bilgisi diğer her şeyin altında yatar; kriptografi birçok konuya yayılır; saldırı ve savunma kümeleri bu temelin üzerine oturur; adli analiz ve yönetişim ise en üstte, uygulamalı deneyim gerektiren kümelerdir.

Çekirdek Konu Kümeleri

Küme 1 — Ağ Temelleri

Ağ temelleri, bilgisayarların birbiriyle nasıl haberleştiğini açıklayan kümedir ve diğer bütün güvenlik konularının altında yatar. Bir saldırının ya da savunmanın nasıl çalıştığını anlamak, önce verinin ağ üzerinde nasıl aktığını anlamayı gerektirir.

Kapsanan konular

- OSI ve TCP/IP modelleri. Ağ iletişimini katmanlara ayıran iki kavramsal çerçeve. OSI modeli yedi katmandan oluşur; her katman bir sonrakine belirli bir hizmet sunar. TCP/IP bu modelin pratikte kullanılan dört katmanlı hâlidir.
- Portlar ve protokoller. Bir port, bir cihazdaki belirli bir servisi adresleyen numaradır (*port*); protokol ise iletişimin kurallarını belirleyen anlaşmadır. HTTP, HTTPS, DNS, SSH gibi protokoller belirli portlar üzerinden çalışır.
- MAC ve IP adresleme. MAC adresi (*Media Access Control*) bir ağ donanımının fiziksel kimliğidir; IP adresi ise cihazın ağ üzerindeki mantıksal konumudur.
- Router, switch ve firewall gibi ağ cihazlarının işlevleri.
- Ağ sorun giderme yöntemleri.

Bu kümeyi öğreten kurslar

CompTIA Network+ (N10-009) kursları bu kümenin saf hâlidir; Jason Dion, Mike Meyers ve Andrew Ramdayal'ın kursları aynı sınav hedeflerini farklı anlatımlarla işler. Ayrıca her etik hacking ve Security+ kursunun ilk bölümleri bu temelleri özetler; Nathan House serisinin ikinci cildi (Network Security) bu kümeyi güvenlik odağıyla tekrar ele alır.

Küme 2 — İşletim Sistemi ve Sistem Güvenliği

Bu küme, bir bilgisayarın kendi içinde nasıl korunduğunu ele alır. Saldırılar çoğunlukla bir işletim sisteminin yanlış ayarlanmış izinlerinden ya da güncellenmemiş bileşenlerinden yararlanır; dolayısıyla sistemin iç işleyişini bilmek hem saldırı hem savunma için zorunludur.

Kapsanan konular

- Linux temelleri ve terminal kullanımı. Kali Linux gibi güvenlik odaklı dağıtımların kurulumu ve kullanımı.

- Kullanıcı izinleri, dosya sahipliği ve erişim denetimi. Bir sistemde hangi kullanıcının neye erişebildiğini belirleyen mekanizmalar.
- Yetki yükseltme (*privilege escalation*). Sınırlı yetkili bir kullanıcının, sistemdeki bir zayıflıktan yararlanarak yönetici yetkisi kazanması. Linux tarafında yanlış ayarlanmış izinler, zamanlanmış görevler (*cron job*) ve SUID çalıştırılabilirleri; Windows tarafında zayıf servis ayarları ve bellekte saklanan kimlik bilgileri başlıca yollardır.
- Uç nokta koruması (*endpoint protection*). Dizüstü, masaüstü ve mobil cihazların korunması; antivirüs, disk şifreleme ve EDR (*Endpoint Detection and Response*, uç noktada tespit ve yanıt) teknolojileri.

Bu kümeyi öğreten kurslar

Tib3rius'un Linux ve Windows Privilege Escalation kursları bu kümenin yetki yükseltme bölümünün standart kaynağıdır. Nathan House'un dördüncü cildi (End Point Protection) uç nokta korumasını kapsar. Zaid Sabih'in etik hacking kursları Linux temellerini ve lab kurulumunu öğretir.

Küme 3 — Kriptografi

Kriptografi, verinin yetkisiz kişilerce okunamayacak biçimde dönüştürülmesi bilimidir. Bu küme diğer kümelere yayılır: ağ güvenliği HTTPS'i, kimlik doğrulama parola saklamayı, adli analiz şifreli diskleri konu edindiğinde hep kriptografiye dayanır.

Kapsanan konular

- Simetrik ve asimetrik şifreleme. Simetrik şifrelemede aynı anahtar hem şifreler hem çözer; asimetrik şifrelemede açık anahtar (*public key*) şifreler, gizli anahtar (*private key*) çözer.
- Özetleme (*hashing*). Bir veriyi geri döndürülemez biçimde sabit uzunlukta bir değere çeviren işlem. Parolalar genellikle açık metin yerine özet hâlinde saklanır.
- Parola ve özet kırma. Zayıf parolaların Hashcat gibi araçlarla deneme yoluyla çözülmesi; bu saldırıya karşı alınan önlemler.
- Şifrelemenin nasıl aşılabildiği ve bu riskin azaltılması.

Bu kümeyi öğreten kurslar

Nathan House'un birinci cildi kriptografi temellerine ayrı bir bölüm ayırır. Atıl Samancıoğlu'nun Türkçe kursu Hashcat ile parola ve özet kırmayı işler. Security+ ve CISSP kursları kriptografiyi kendi alanları içinde ele alır.

Küme 4 — Ağ ve Sistem Saldırıları (Ofansif)

Bu küme, bir sistemin saldırganın bakışıyla nasıl ele geçirildiğini öğretir. Amacı zarar vermek değil, zayıflıkları kötü niyetli biri bulmadan önce ortaya çıkarmaktır; bu yüzden etik hacking ve sızma testi (*penetration testing*) olarak adlandırılır.

Kapsanan konular

- Bilgi toplama (*reconnaissance*). Hedef hakkında açık kaynaklardan bilgi derleme (*OSINT*, açık kaynak istihbaratı); ağ ve port tarama.
- Kablosuz ağ saldırıları. WEP, WPA ve WPA2 şifreleme protokollerinin kırılması.
- Araya girme saldırıları (*man-in-the-middle*). İki taraf arasındaki trafiğin ele geçirilip değiştirilmesi; DNS yanıltma (*DNS spoofing*).
- Sunucu ve istemci tarafı saldırılar. Metasploit gibi çerçevelerle bilinen açıkların sömürülmesi; kullanıcıyı kandırarak zararlı kod çalıştırma.
- Sömürü sonrası (*post-exploitation*). Ele geçirilen sistemde kalıcı olma, tuş kaydı (*keylogging*), başka sistemlere yayılma ve iz silme.
- Saldırı araçlarının programlanması. Python ile tarayıcı, backdoor, keylogger gibi araçların sıfırdan yazılması.

Bu kümeyi öğreten kurslar

Zaid Sabih'in Learn Ethical Hacking From Scratch ve Learn Python & Ethical Hacking From Scratch kursları bu kümenin en kapsamlı kaynaklarıdır. Atıl Samancıoğlu'nun Türkçe kursu aynı konuları Türkçe anlatır. CEH v13 hazırlık kursları bu kümeyi sertifika hedefiyle paketler.

Küme 5 — Web Uygulama Güvenliği

Web uygulamaları, internete açık olmaları nedeniyle en sık saldırılan hedeflerdir. Bu küme, web uygulamalarındaki yaygın açıkları ve bunların nasıl bulunup giderildiğini ele alır. Bug bounty (*bug bounty*, açık bulana ödül) programları bu kümenin pratik uygulama alanıdır.

Kapsanan konular

- SQL enjeksiyonu (*SQL injection*). Bir uygulamanın veritabanı sorgusuna kötü niyetli kod sokularak veritabanının ele geçirilmesi.
- Siteler arası betik çalıştırma (*XSS, cross-site scripting*). Bir web sayfasına, başka kullanıcıların tarayıcısında çalışacak zararlı kodun yerleştirilmesi.
- Siteler arası istek sahteciliği (*CSRF, cross-site request forgery*). Kullanıcının haberi olmadan, oturumunu kullanarak istek gönderilmesi.

- Erişim denetimi açıkları ve açık yönlendirme (*open redirect*).
- Dosya yükleme ve kod çalıştırma açıkları.
- Açık bulma metodolojisi ve sorumlu bildirim (*responsible disclosure*).

Bu kümeyi öğreten kurslar

Martin Voelk'in The Ultimate Web Application Bug Bounty Hunting Course ve Wesley Thijs'in (Uncle Rat) rehberi bu kümeye odaklanır. Zaid Sabih'in etik hacking kursunun son bölümü de web açıklarını kapsar.

Küme 6 — Savunma ve İzleme (Defansif)

Bu küme, saldırıların tespit edilip yanıtlandığı mavi takım tarafını ele alır. Güvenlik Operasyon Merkezi (*SOC, Security Operations Center*), bir kurumun güvenlik olaylarını sürekli izleyen ekip ve altyapıdır. Bu kümeyi anlamak Küme 4'ü, yani saldırıların nasıl yapıldığını bilmeyi gerektirir; çünkü ne arandığı bilinmeden izleme yapılamaz.

Kapsanan konular

- SOC süreçleri, roller ve sorumluluklar. Olayların seviyelere göre (L1, L2) nasıl ele alındığı.
- SIEM (*Security Information and Event Management*, güvenlik bilgi ve olay yönetimi). Farklı kaynaklardan gelen logları toplayıp ilişkilendiren ve alarm üreten sistem. Splunk, QRadar, ArcSight, ELK başlıca araçlardır.
- Log analizi, dashboard ve alarm oluşturma.
- Cyber Kill Chain. Bir saldırının adımlarını (bilgi toplamadan hedefe ulaşmaya) modelleyen çerçeve. Savunmada, saldırıyı hangi adımda kesmek gerektiğini belirlemek için kullanılır.
- Tehdit istihbaratı ve olay müdahalesi (*incident response*).

Bu kümeyi öğreten kurslar

SOC ve SIEM kursları (Splunk odaklı olanlar dâhil) bu kümeyi işler. Nathan House'un dördüncü cildindeki tehdit izleme bölümü, CySA+ kursunun güvenlik operasyonları alanı ve CISSP'nin yedinci alanı bu kümeye katkı verir.

Küme 7 — Zararlı Yazılım Analizi ve Dijital Adli Analiz

Bu küme, zararlı yazılımların nasıl çalıştığının çözümlenmesini ve bir olay sonrası dijital kanıtın incelenmesini ele alır. İleri seviye bir kümedir; işletim sistemi iç işleyişi ve temel programlama bilgisi gerektirir.

Kapsanan konular

- Tersine mühendislik (*reverse engineering*). Derlenmiş bir programın, kaynak koduna erişmeden iç işleyişinin çözülmesi.
- Statik ve dinamik analiz. Statik analiz programı çalıştırmadan inceler; dinamik analiz kontrollü bir ortamda çalıştırarak davranışını gözlemler.
- Analiz araçları. Ghidra gibi tersine mühendislik araçlarının kullanımı.
- Farklı platformların zararlıları: yerel çalıştırılabilirler, .NET ve Java tabanlı zararlılar, fidye yazılımları (*ransomware*).

Bu kümeyi öğreten kurslar

Paul Chin'in Reverse Engineering and Malware Analysis serisi (temel, orta ve Ghidra kursları) bu kümenin standart kaynağıdır.

Küme 8 — Yönetişim, Risk ve Uyumluluk

Bu küme teknik değil yönetsel bir kümedir ve güvenliğin kurumsal boyutunu ele alır. Teknik beceri ne kadar yüksek olursa olsun, bir kurumda güvenlik politikalar, risk değerlendirmesi ve yasal uyumlulukla birlikte yürütülür.

Kapsanan konular

- Risk yönetimi süreci. Tehditlerin ve zayıflıkların belirlenmesi, önceliklendirilmesi ve azaltılması.
- Güvenlik politikaları ve kontroller. İdari, teknik ve fiziksel kontrol türleri.
- Varlık güvenliği ve veri sınıflandırması.
- Uyumluluk ve yasal çerçeveler. Türkiye bağlamında KVKK (Kişisel Verilerin Korunması Kanunu); uluslararası bağlamda ilgili standartlar.
- Güvenlik farkındalığı ve sosyal mühendislik savunması.

Bu kümeyi öğreten kurslar

CISSP kursları (özellikle birinci ve ikinci alanlar) bu kümenin en kapsamlı kaynağıdır; CISSP teknik bir sertifikadan çok bir yönetim sertifikasıdır. Information Security Management Fundamentals kursu teknik olmayan bir girişi, Security+'ın yönetişim alanı ise temel düzeyi sağlar. Türkçe Bilgi Güvenliği Farkındalık Eğitimi, KVKK ve sosyal mühendislik tarafını işler.

Kümelerden Ders Dizisi Kurmak

Sekiz küme bir önkoşul grafiği oluşturur ve ders dizisi bu grafiğe uyularak kurulur. Aşağıdaki sıra, bir kümenin ancak kendisinden önce gelen kümeler öğrenildiğinde anlamlı olduğu ilkesine dayanır.

Temel katman (önkoşulsuz)

İlk sırada Küme 1 (Ağ Temelleri) ve Küme 2 (İşletim Sistemi ve Sistem Güvenliği) gelir. Bunlar başka hiçbir kümeyi gerektirmez ve diğer her şeyin altında yatar. Bir öğrenci bu ikisini atlarsa, sonraki kümelerdeki her tekniği ezberlemek zorunda kalır; çünkü tekniğin *neden* çalıştığını açıklayan bilgi bu katmandadır.

Çekirdek katman

İkinci sırada Küme 3 (Kriptografi) gelir. Diğer kümelere yayıldığı için erken öğrenilmesi gerekir; ancak kendi başına bir uygulama alanı olmadığından temel katmandan sonra konumlanır.

Uygulama katmanı

Üçüncü sırada saldırı ve savunma kümeleri gelir: Küme 4 (Ağ ve Sistem Saldırıları), Küme 5 (Web Uygulama Güvenliği) ve Küme 6 (Savunma ve İzleme). Burada bir sıralama tercihi vardır: saldırı kümeleri savunma kümesinden önce öğretilir, çünkü neyin izleneceği ancak saldırının nasıl yapıldığı bilinince anlaşılır. Web güvenliği, ağ ve sistem saldırılarından bağımsız olarak da öğrenilebilir; bu yüzden paralel konumlandırılabilir.

İleri katman

Son sırada Küme 7 (Zararlı Yazılım Analizi) ve Küme 8 (Yönetişim) gelir. Küme 7 teknik olarak en derin önkoşul yüküne sahiptir ve en sona bırakılır. Küme 8 teknik önkoşul gerektirmez; ancak kurumsal bağlamı ileri bir öğrenciye daha anlamlı geldiğinden pratikte sona konur. İsteğe göre erken de verilebilir.

Sertifikaların kümelerle ilişkisi

Sertifikalar ayrı dersler değil, kümelerin paketleridir ve bu paketleme ilişkisi müfredatta açıkça gösterilmelidir:

- Network+ büyük ölçüde Küme 1'dir.
- Security+ Küme 1, 2, 3 ve 8'in temel düzeyini birleştirir; geniş ama yüzeysel bir giriştir.
- CySA+ Küme 6'ya odaklanır.
- CISSP Küme 8 ağırlıklıdır, diğer kümelere yönetsel düzeyde değinir.

- CEH Küme 4'ü sertifikalaştırır.
- AWS Security Specialty, kümelerin tamamını bulut bağlamına taşıyan dikey bir uzmanlıktır ve ancak temel kümeler oturduktan sonra anlamlıdır.

Bu ilişki, bir öğrencinin "hangi sertifikayı alsam" sorusunu, "hangi kümeleri öğrenmem gerekiyor" sorusuna çevirir. Müfredatın değeri de buradadır: sertifika başlıklarını değil, altlarındaki konu kümelerini öğretir.

Küme 9 — Kimlik ve Erişim Yönetimi

Kimlik ve erişim yönetimi (*IAM, Identity and Access Management*), bir sistemde kimin kim olduğunun doğrulanmasını ve neye erişebileceğinin belirlenmesini ele alan kümedir. Saldırıların büyük bölümü teknik bir açıktan değil, çalınmış ya da zayıf bir kimlik bilgisinden yararlanır; bu yüzden bu küme hem saldırı hem savunma tarafında merkezîdir.

İki kavram sık karıştırılır ve ayrımı bu kümenin temelidir. Kimlik doğrulama (*authentication*) kişinin iddia ettiği kişi olduğunun kanıtlanmasıdır; parola girmek buna örnektir. Yetkilendirme (*authorization*) ise doğrulanmış kişinin hangi kaynaklara erişebileceğinin belirlenmesidir. Bir kullanıcı sisteme doğru parolayla girebilir (doğrulanmış) ama yönetici paneline erişemeyebilir (yetkilendirilmemiş).

Kapsanan konular

- Kimlik doğrulama yöntemleri. Bilinen bir şey (parola), sahip olunan bir şey (telefon, güvenlik anahtarı) ve olunan bir şey (parmak izi) olmak üzere üç faktör. Çok faktörlü doğrulama (*MFA, Multi-Factor Authentication*) bunlardan en az ikisini birlikte ister; bir parola çalınsa bile ikinci faktör olmadan giriş engellenir.
- Tek oturum açma (*SSO, Single Sign-On*). Kullanıcının bir kez doğrulanıp birden fazla sisteme girmesini sağlayan yapı.
- Erişim denetimi modelleri. Rol tabanlı erişim denetimi (*RBAC, Role-Based Access Control*), yetkilerin tek tek kullanıcılara değil rollere verildiği ve kullanıcıların rollere atandığı modeldir.
- En az yetki ilkesi (*principle of least privilege*). Bir kullanıcıya ya da sürece, işini yapması için gereken en az yetkinin verilmesi. Bu ilke, bir hesap ele geçirildiğinde saldırganın erişebileceği alanı daraltır.
- Kimlik bilgisi saldırıları. Çalınan özet değerlerin yeniden kullanıldığı saldırılar, oturum çalma ve bunlara karşı önlemler.

Bu kümeyi öğreten kurslar

CISSP'nin beşinci alanı bu kümenin en kapsamlı kaynağıdır. Security+'ın ilgili bölümü temel düzeyi verir; AWS Security Specialty kursu bu kümeyi bulut bağlamında (IAM politikaları, rol tabanlı erişim) ayrıntılı işler.

Küme 10 — Bulut Güvenliği

Bulut güvenliği, kurumların kendi sunucuları yerine AWS, Azure ya da Google Cloud gibi sağlayıcıların altyapısında çalıştırdığı sistemlerin korunmasını ele alır. Önceki kümelerdeki kavramların çoğu burada da geçerlidir, ancak sorumluluğun paylaşılması ve kaynakların yazılımla yönetilmesi bu kümeyi ayrı bir disiplin yapar.

Kümenin merkezinde paylaşılan sorumluluk modeli (*shared responsibility model*) yatar. Bu modelde, altyapının fiziksel güvenliğinden sağlayıcı sorumludur; sistemin ayarları, erişim politikaları ve verinin korunmasından ise müşteri sorumludur. Bulut ihlallerinin büyük bölümü sağlayıcının açığından değil, müşterinin yanlış ayarlanmış bir kaynağından kaynaklanır; örneğin herkese açık bırakılmış bir depolama kovası.

Kapsanan konular

- Bulutta kimlik ve erişim yönetimi. Kaynaklara erişimin politikalarla tanımlanması; bir önceki kümenin bulut karşılığı.
- Şifreleme ve anahtar yönetimi. Bulut sağlayıcısının anahtar yönetim servisiyle (AWS'de *KMS, Key Management Service*) verinin hem saklanırken hem aktarılırken şifrelenmesi.
- Tehdit tespiti ve izleme. Bulut ortamındaki şüpheli etkinliğin otomatik tespiti (AWS'de *GuardDuty*) ve tüm işlemlerin kaydı (*CloudTrail*).
- Ağ güvenliği. Sanal ağların yalıtımı, güvenlik grupları ve erişim denetim listeleri.
- Bulutta olay müdahalesi ve uyumluluk gereksinimleri.

Bu kümeyi öğreten kurslar

Stephane Maarek'in AWS Certified Security Specialty kursu bu kümenin standart kaynağıdır. Bu küme ancak temel kümeler (özellikle Küme 1, 2, 3 ve 9) oturduktan sonra anlamlıdır; bulut, bu kavramların yeni bir ortama taşınmış hâlidir.

Küme 11 — Mobil ve IoT Güvenliği

Bu küme, geleneksel bilgisayarların dışındaki cihazların güvenliğini ele alır: akıllı telefonlar, tabletler ve nesnelerin interneti (*IoT, Internet of Things*) olarak adlandırılan internete bağlı günlük cihazlar. Bu cihazlar sayıca çok, güncelleme bakımından zayıf ve çoğu zaman güvenlik düşünülmeden tasarlandığı için genişleyen bir saldırı yüzeyi oluşturur.

Kapsanan konular

- Mobil cihaz güvenliği. Uygulama izinleri, cihaz şifreleme, zararlı uygulamalar ve mobil işletim sistemlerinin güvenlik modeli.
- Mobil uygulama analizi. Bir mobil uygulamanın tersine mühendislikle incelenmesi; Küme 7 ile kesişir.

- IoT cihazlarının zayıflıkları. Varsayılan parolalar, güncellenmeyen yazılımlar ve şifrelenmemiş iletişim. Çok sayıda ele geçirilmiş IoT cihazının birlikte saldırıya koşulması (*botnet*) bu kümenin önemli bir tehdididir.
- Donanım güvenliği temelleri. Fiziksel erişimle yapılan saldırılar ve bunlara karşı önlemler.

Bu kümeyi öğreten kurslar

Nathan House serisinin mobil cihaz güvenliği bölümleri ve çeşitli bağımsız mobil güvenlik kursları bu kümeye katkı verir. Türkçe Bilgi Güvenliği Farkındalık Eğitimi mobil cihaz güvenliğinin temel farkındalık düzeyini içerir. Bu küme, incelenen kurslarda en az kapsanan alandır ve müfredatta ek kaynak gerektirebilir.

Küme 12 — Güvenli Yazılım Geliştirme

Bu küme, yazılımın baştan güvenli yazılmasını ele alır. Önceki kümeler çoğunlukla hazır bir sistemdeki açığı bulmayla ilgiliyken, bu küme açığın hiç oluşmaması için geliştirme aşamasında alınan önlemlere bakar. Bir açığı sonradan kapatmak, geliştirme sırasında önlemekten çok daha maliyetlidir; kümenin pratik değeri buradadır.

Kapsanan konular

- Güvenli kodlama ilkeleri. Kullanıcıdan gelen verinin doğrulanması, güvenli varsayılan ayarlar ve yaygın hatalardan kaçınma. Küme 5'teki web açıklarının çoğu (SQL enjeksiyonu, XSS) kök nedeni doğrulanmamış girdidir; bu küme sorunu kaynağında ele alır.
- Güvenli geliştirme yaşam döngüsü (*SDLC, Software Development Life Cycle*). Güvenliğin tasarımdan teste kadar her aşamaya yerleştirilmesi.
- Kod gözden geçirme ve güvenlik testi. Statik kod analizi (kod çalıştırılmadan incelenir) ve dinamik test (çalışan uygulama test edilir).
- Bağımlılık güvenliği. Projede kullanılan dış kütüphanelerdeki bilinen açıkların izlenmesi.

Bu kümeyi öğreten kurslar

CISSP'nin sekizinci alanı bu kümeyi yönetsel düzeyde kapsar. İncelenen kurslarda bu küme büyük ölçüde eksiktir; saldırı odaklı kurslar açığın nasıl sömürüldüğünü gösterir ama nasıl önleneceğini sistematik olarak öğretmez. Bir yazılım geliştirici için bu küme, saldırı kümelerinin tamamlayıcısıdır.

Küme Ötesi — Sosyal Mühendislik

Sosyal mühendislik (*social engineering*), teknik bir açıktan değil insan davranışından yararlanan saldırı türüdür ve tek bir kümeye ait olmadığı için ayrı ele alınır. Saldırganın hedefi sistemi değil, sistemi kullanan kişiyi kandırmaktır; bu yüzden en güçlü teknik savunmalar bile sosyal mühendisliğe karşı tek başına yetersiz kalır.

Kapsanan konular

- Oltalama (*phishing*). Meşru görünen sahte e-posta ya da mesajlarla kullanıcının kimlik bilgisini ya da parasını ele geçirme. Belirli bir kişiyi hedefleyen daha özenli türüne hedefli oltalama (*spear phishing*) denir.
- Diğer kanallar. Telefonla kandırma (*vishing*) ve SMS yoluyla kandırma (*smishing*).
- İnsan psikolojisinin kullanımı. Aciliyet, otorite ve güven gibi duyguların saldırıda nasıl araçsallaştırıldığı.
- Savunma. Kullanıcı farkındalığı eğitimi, şüpheli iletişimi doğrulama alışkanlığı ve çok faktörlü doğrulamanın bu saldırılardaki rolü.

Bu kümeyi öğreten kurslar

Nathan House'un birinci cildi, Atıl Samancıoğlu'nun Türkçe kursu ve Türkçe Bilgi Güvenliği Farkındalık Eğitimi bu konuyu işler. Sosyal mühendislik hem Küme 4'ün (saldırı başlangıcı olarak) hem Küme 8'in (farkındalık ve politika olarak) parçasıdır; bağımsız ele alınması bu çift aidiyetten kaynaklanır.

Uygulamalı Beceri Katmanı

Konu kümeleri bilgiyi düzenler, ancak güvenlik bir okuma değil yapma disiplinidir. Bir SQL enjeksiyonunu tanımlayabilen öğrenci ile onu gerçek bir hedefte bulup sömürebilen öğrenci arasındaki fark, yalnızca uygulamayla kapanır. Bu yüzden her küme teorik içeriğinin yanında uygulamalı bir bileşen taşımalıdır; aksi hâlde müfredat ezberci kalır.

Olay müdahalesi (*incident response*) bu katmanın özel bir örneğidir. Bir saldırı tespit edildikten sonra atılacak adımların sırası — olayın sınırlandırılması, tehdidin temizlenmesi, sistemin kurtarılması ve çıkarılan derslerin kaydı — yalnızca anlatılarak değil, benzetim yoluyla öğretilir. Bu nedenle olay müdahalesi, Küme 6'nın (Savunma ve İzleme) bir alt başlığı olmaktan çok, uygulamalı bir egzersiz olarak kurgulanmalıdır.

Uygulama ortamları

- Sanal makine lab'ları. Kasıtlı olarak açıklı bırakılmış sistemler (Tib3rius'un kurslarındaki Debian ve Windows sanal makineleri gibi) üzerinde, gerçek bir hedefe zarar vermeden teknik denemek.
- Bayrak yakalama yarışmaları (*CTF, Capture The Flag*). Belirli açıkların çözülerek gizli bir "bayrağın" ele geçirildiği, oyunlaştırılmış güvenlik egzersizleri.
- Çevrimiçi platformlar. TryHackMe ve benzeri platformlar, rehberli alıştırmalarla teoriyi uygulamaya bağlar.
- Sertifika sınavları. OSCP (*Offensive Security Certified Professional*) gibi uygulamalı sınavlar, bilgiyi değil beceriyi ölçtükleri için bu katmanın doğal hedefidir.
- Bug bounty platformları. Küme 5'in gerçek sistemler üzerinde, yasal çerçevede uygulanma alanı.

Bu katman ayrı bir küme değildir; her kümenin üzerine binen ve onu beceriye çeviren bir boyuttur. Müfredat tasarımında her teorik ders, bu ortamlardan en az biriyle eşleştirilmelidir.

Siber güvenliğin "en temel ilkesi" sorusunun tek bir kesin cevabı yoktur; alan birkaç ilke üzerine kuruludur ve hangisinin en temel olduğu bakış açısına göre değişir.

Pratikte en çok işe yarayan ve en çok ihlal edilen ilke en az yetki ilkesidir (*principle of least privilege*): her kullanıcıya, sürece ya da bileşene, işini yapması için gereken en az yetki verilir, fazlası değil. Verilmeyen yetki istismar edilemez; bir hesap ele geçirildiğinde saldırganın ulaşabileceği alan, o hesabın zaten sahip olmadığı yetkilerle sınırlanır.

Alanın kavramsal temeli sorulduğunda ise cevap CIA üçlüsüdür. Bu üçlü, güvenliğin neyi koruduğunu tanımlar ve her güvenlik önlemi sonuçta bu üçünden birine hizmet eder:

- Gizlilik (*confidentiality*): verinin yalnızca yetkili kişilerce okunabilmesi.
- Bütünlük (*integrity*): verinin yetkisiz biçimde değiştirilememesi.
- Erişilebilirlik (*availability*): verinin ve sistemin gerektiğinde erişilebilir olması.

Bu iki ilkenin yanında, güvenliğin pratikte nasıl uygulanacağını belirleyen iki tamamlayıcı ilke bulunur:

- Derinlemesine savunma (*defense in depth*): tek bir önleme güvenmek yerine katman katman korumak. Bir katman aşılsa bile diğerleri saldırıyı durdurur.

- Güvenliğin bir ürün değil süreç olması. Bruce Schneier'e atfedilen bu ilkeye göre güvenlik kurulup bırakılan bir şey değil, sürekli bakım isteyen bir uğraştır.

Özetle: tek bir cümleyle "pratikte en çok işe yarayan ve en çok ihlal edilen" ilke istenirse cevap en az yetki ilkesidir; "alanın kavramsal temeli" istenirse cevap CIA üçlüsüdür.

Sonuç

İncelenen çok sayıda kurs, görünürdeki çeşitliliğine rağmen sekiz konu kümesine indirgenir. Bu, bir müfredat kurarken kurs başlığı eklemenin yanıltıcı olduğunu gösterir; iki farklı başlıklı kurs çoğu zaman aynı kümeyi öğretir, dolayısıyla müfredata değer katmaz. Asıl katkı, kümeleri önkoşul grafiğine uygun bir sırayla dizmekten gelir.

Bu çerçevenin pratik karşılığı, ders tasarımının kurs seçimiyle değil küme seçimiyle başlamasıdır. Önce hangi kümelerin hangi derinlikte öğretileceğine karar verilir; ardından her küme için o kümeyi en iyi öğreten kurs kaynak olarak atanır. Aynı kümeyi öğreten birden fazla kurs varsa biri seçilir, diğerleri yedek olarak tutulur; bunların hepsini müfredata koymak tekrardan başka bir şey üretmez.

Çerçevenin sınırı, pratik uygulamayı tam yansıtamamasıdır. Konu kümeleri bilgiyi düzenler ama beceri yalnızca uygulamayla, lab ortamlarında ve gerçek senaryolarda kazanılır. Bu yüzden her küme için teorik içeriğin yanına uygulamalı bir bileşen (sanal makine lab'ı, CTF, bug bounty platformu) eklenmelidir; aksi hâlde müfredat ezberci kalır.

Açık kalan soru, kümelerin hedef kitleye göre nasıl ağırlıklandırılacağıdır. Savunma tarafında kariyer hedefleyen biri için Küme 6 merkezdeyken, sızma testi hedefleyen biri için Küme 4 ve 5 öne çıkar. Dolayısıyla tek bir "genel ders" dizisi değil, ortak bir temel üzerine kurulan dallanan diziler düşünmek daha doğrudur; temel katman (Küme 1-2-3) herkes için ortaktır, uygulama ve ileri katmanlar hedefe göre ayrışır.

Kaynaklar

- CompTIA. Network+ (N10-009) ve Security+ (SY0-701) Sınav Hedefleri. CompTIA sertifika dokümantasyonu.
- CompTIA. Cybersecurity Analyst+ (CySA+ CS0-003) Sınav Hedefleri.
- (ISC)². CISSP Common Body of Knowledge, sekiz alan yapısı.
- Lockheed Martin. Cyber Kill Chain çerçevesi.
- EC-Council. Certified Ethical Hacker (CEH) v13 program yapısı.
- Kurs içerikleri Udemy kurs sayfalarından ve Class Central, StationX, Careers360 derlemelerinden alınmıştır.